

PENETRATION TESTING REPORT

Web Application Security Assessment — Mediroza General Hospital

Target: <code>https://medirozahospital.com</code>	Prepared By: Suraya Azeez	Cybersecurity Mentor: Waqas Karim, CCIE
Type: Black-Box Pentest	Organisation: Networkwalks	Classification: Confidential
Batch/Phase: Batch B082 Week 4 Capstone	Overall Risk Rating: CRITICAL	Date: September 2026

1. EXECUTIVE SUMMARY

An authorized black-box penetration test was conducted on the web infrastructure of **Mediroza General Hospital** (`https://medirozahospital.com`). The target provided explicit written authorization for this assessment. The objective was to identify security vulnerabilities, demonstrate real-world risk through controlled exploitation, and formulate actionable recommendations to secure organizational assets.

Overall Security Posture: CRITICAL

A total of **seven (7) security vulnerabilities** were identified, ranging from Medium to Critical severity. The core attack chain enabled an unauthenticated attacker to exploit a SQL injection vulnerability on the login page to bypass authentication, crack password-protected patient laboratory reports, parse document metadata for internal server paths, and gain full plain-text access to staff salary records and corporate shareholding details. Immediate remediation is strongly advised.

2. SCOPE & METHODOLOGY

2.1 Assessment Scope

Target Identifier	Scope Description	Status / Restrictions
<code>https://medirozahospital.com</code>	Full web application infrastructure & endpoints	In Scope (Explicit Written Permission)
Social Engineering / DoS	Phishing, Denial of Service, physical security testing	Out of Scope (Strictly Prohibited)

2.2 Testing Methodology

The assessment followed a structured 4-phase black-box penetration testing framework:

- **Reconnaissance:** Active and passive footprinting to map endpoints, service banners, and exposed interfaces.
- **Vulnerability Identification:** Analyzing application logic, error messaging, and input handling mechanisms for flaws.
- **Exploitation:** Constructing controlled exploits to demonstrate critical impacts without degrading system integrity.
- **Documentation & Reporting:** Risk-scoring findings via standard metrics and detailing clear mitigation guidance.

2.3 Technical Toolset

Tools utilized during the engagement included: `curl`, Browser Developer Tools, Networkwalks Hash Calculator, Networkwalks Password Cracker, `qpdf`, `exiftool`, `wget`, Burp Suite, and SQL parsing utilities.

3. FINDINGS & PROOF OF EXPLOITATION

3.1 Vulnerability Summary Table

#	VULNERABILITY TITLE	IMPACTED LOCATION / PARAMETER	RISK SEVERITY
1	Username Enumeration on Login Interface	patient/login.php	MEDIUM
2	SQL Injection Authentication Bypass	patient/login.php (username field)	CRITICAL
3	Unrestricted Access to Confidential Patient PDFs	patient/reports/	HIGH
4	Weak PDF Passphrase Encryption Standard	patient_report_*.pdf	HIGH
5	Sensitive Administrative Notes in Metadata	patient_report_3.pdf	MEDIUM
6	Exposed Directory Listing on Backup Folder	/old/ directory	CRITICAL
7	Plain-Text Staff Salary & Shareholder Disclosure	/old/mediroza_db_backup_2019.sql	CRITICAL

3.2 Detailed Findings Breakdown

Finding 1: Username Enumeration via Differentiated Error Messages

MEDIUM

Location: patient/login.php

Description: The authentication mechanism provides distinct error messages for non-existent accounts versus incorrect passwords on valid accounts, allowing attackers to systematically enumerate valid usernames.

Proof of Concept:

- Submitting non-existent user bob yields: "Username not found"
- Submitting valid account admin yields: "Incorrect password"

This confirmed that admin is an active user account on the target system.

Finding 2: SQL Injection Login Bypass

CRITICAL

Location: patient/login.php

Description: The username parameter fails to sanitize user input prior to database query execution. Inserting SQL syntax alters the query logic, allowing total authentication bypass.

Proof of Concept:

Submitting single quote syntax admin' triggered a raw MySQL syntax error:

```
Warning: mysqli_query(): You have an error in your SQL syntax; check the manual near '' at line 1
```

Crafting the payload admin' -- altered the underlying query logic:

```
SELECT * FROM users WHERE username='admin' -- AND password='...'
```

The password verification clause was commented out, resulting in immediate administrative portal access.

Finding 3: Unrestricted Confidential PDF Access

HIGH

Location: `patient/reports/`

Description: Post-authentication portal access granted direct access to confidential medical lab reports belonging to multiple patients (`patient_report_1.pdf`, `patient_report_2.pdf`, and `patient_report_3.pdf`) without row-level authorization checks.

Finding 4: Weak PDF Passphrases Crackable via Wordlists

HIGH

Location: Encrypted PDF Lab Reports

Description: Downloaded medical PDF documents utilized weak password protection schemes vulnerable to offline dictionary cracking attacks.

Cracking Results:

- `patient_report_1.pdf` — Cracked in <1 sec using basic dictionary: `123456`
- `patient_report_2.pdf` — Cracked in <1 sec using basic dictionary: `password`
- `patient_report_3.pdf` — Cracked using JTR extended wordlist: `!@#$$%^&`

Finding 5: Sensitive Metadata Disclosure in PDF Properties

MEDIUM

Location: `patient_report_3.pdf`

Description: Decrypting and inspecting PDF document metadata using `exiftool` revealed hidden administrative comments left prior to publication.

```
Author   : j.malik
Comments : DB backup moved to /old before site migration, do not delete
```

This comment disclosed the exact location of a server backup directory.

Finding 6 & 7: Unrestricted Directory Listing & Plain-Text Database Backup Exposure

CRITICAL

Location: `https://medirozahospital.com/old/mediroza_db_backup_2019.sql`

Description: Navigating to the disclosed `/old/` directory confirmed directory browsing was enabled. The directory hosted an unencrypted database dump file containing sensitive organizational data.

Exfiltrated Plain-Text Data:

- **Staff Payroll:** Complete personal details, national ID numbers, job titles, and monthly salaries (ZAR) for all 30 hospital employees.
- **Corporate Governance:** Full legal names and equity shareholding percentages for all 10 hospital shareholders.
- **Attribution:** Confirmed IT Administrator Jameel Malik (`j.malik`) created the backup, tying the entire exploit chain together.

4. FULL ATTACK CHAIN SUMMARY

1. **Reconnaissance:** Extracted endpoints from `robots.txt` (`/patient`, `/staff`, `/old`).
2. **Enumeration:** Identified `admin` username via differentiated error response logic.
3. **Authentication Bypass:** Executed SQL injection payload (`admin' --`) to bypass portal authentication.
4. **Exfiltration:** Downloaded 3 encrypted confidential patient pathology laboratory PDF files.
5. **Cryptanalysis:** Extracted hashes and cracked passphrases (`123456`, `password`, `!@#$$%^&`).
6. **Metadata Analysis:** Discovered internal comment by `j.malik` referencing `/old` directory.
7. **Server Data Breach:** Downloaded `mediroza_db_backup_2019.sql` via exposed directory index, obtaining 30 employee salary records and 10 shareholder equity structures.

5. RECOMMENDATIONS & ACTION PLAN

5.1 Fix Username Enumeration

Standardize all authentication failure responses to a generic message: *"Invalid credentials. Please try again."*

5.2 Remediate SQL Injection (Critical)

Replace raw dynamic SQL query assembly with parameterized prepared statements across all input forms:

```
<?php
$stmt = $pdo->prepare('SELECT id, username FROM users WHERE username = :user AND password = :pass');
$stmt->execute(['user' => $username, 'pass' => $password_hash]);
$user = $stmt->fetch();
?>
```

5.3 Strengthen PDF Document Protection

Store medical reports outside the public web root. Enforce server-side authorization checks prior to streaming files. Mandatory encryption passphrases must enforce a minimum length of 12+ characters using complex character sets (AES-256 standard).

5.4 Metadata Sanitization Pipeline

Implement automated metadata stripping using `exiftool -all=` prior to distributing documents externally.

5.5 Disable Directory Indexes & Secure Backups

Disable Apache directory browsing by adding `Options -Indexes` to server configuration or `.htaccess`. Instantly remove database backups from web-accessible root folders.

6. CONCLUSION

The penetration test revealed severe systemic weaknesses permitting full compromised access to confidential patient health records and sensitive corporate financial data. Implementing the recommended remediation controls—specifically prepared statements, strict access controls, and proper server hardening—will effectively neutralize these attack vectors.